🌐 令和3年春季 应用情报技术者考试 (AP) 下午问1【信息安全】深度全解析 ✨

本题围绕**DNS域名系统安全与Web服务器认证**展开。题目展现了典型的DNS篡改攻击（A记录改篡）、DNS缓存毒化（DNS Cache Poisoning）风险以及扩展验证证书（EV证书）的作用。以下为您带来图文并茂的全面解析！🎯

🏢 一、 案例背景与攻击全景图

- 🏢 **部署架构**：R公司（软件开发商）在数据中心DMZ区部署了Web服务器、权威DNS服务器和缓存DNS服务器。
  - **权威DNS服务器**：存放R公司域名的解析记录（如A记录），对外回答DNS查询。
  - **缓存DNS服务器**：仅供内网/特定用户递归查询，并缓存查询结果。
- 🚨 **安全事件（Incident）**：
  1. 客户Y公司反映，其员工通过R公司官网上的链接感染了木马。
  2. 调查发现，R公司**权威DNS服务器**上针对官网Web服务器的**A记录被篡改为恶意网站IP**。
  3. 原因：权威DNS服务器的DNS软件版本过旧，被攻击者利用漏洞**夺取了管理员权限（管理者権限）**，直接登录篡改了Zone文件。

📝 二、 设问详细解析与避坑指南

💡 设问 1：解析路径与伪造IP响应者

> 💡 **问题**：Y公司PC被引导至伪造网站时，可能向Y公司PC返回伪造IP地址的DNS服务器有哪些？（多选）

- ✅ **正解**：`ウ` (R社の権威DNSサーバ)、`エ` (Z社のDNSサーバ)
- 🧠 **深度逻辑与解析**：
  1. **解析路径**：Y公司PC ➔ Z公司DNS服务器（Y公司签约ISP的缓存DNS） ➔ R公司权威DNS服务器。

2. **谁返回了伪造IP？**：
    - R公司的权威DNS服务器源头A记录被改篡，因此它会向外返回伪造IP。
    - Z公司的DNS服务器接收并缓存了该伪造IP，随后直接返回给Y公司的PC。
3. **避坑**：DNS根服务器仅做顶级域指引，不存具体A记录；R公司的缓存DNS仅供内网使用，未参与Y公司的域名解析。

💡 设问 2：原因调查与DNS缓存生效期

- **(1) 空白 a（权威DNS漏洞导致的后果）** 🔑
    - ✅ **正解**：`ア` (管理者権限 / 管理员权限)。
    - 🧠 **解析**：日志显示有非工作时间的登录痕迹。攻击者利用旧版本DNS软件漏洞夺取了**管理员权限**，进而远程登录并直接修改了A记录文件。
- **(2) 下划线②（事故期间R公司官网真实访问量极低的原因）** 📉
    - ✅ **正解**：`顧客がR社の偽サイトに誘導されたから` （客户被引导至R公司的假冒网站 / 18字）。
    - 🧠 **解析**：权威DNS被改篡后，外部绝大多数客户在进行域名解析时，都被解析到了攻击者搭建的伪造网站（假官网），导致真实Web服务器几乎接收不到外部流量。
- **(3) 下划线③（恢复正确A记录后，Y公司仍需一段时间才能正常访问的原因）** ⏳
    - ✅ **正解**：`エ` (Z社のDNSサーバ)。
    - 🧠 **解析**：即便R公司修复了权威DNS上的A记录，Z公司的DNS服务器（ISP缓存DNS）中仍存有旧的（伪造的）缓存记录。只有等TTL（生存时间）过期、缓存失效后，Z公司DNS才会重新向R公司权威DNS查询最新的正确IP。

💡 设问 3：安全对策强化与攻击防御

- **(1) 下划线④（防范权威DNS同类事故再次发生的最有效对策）** 🛠️
    - ✅ **正解**：`エ` (定期的に脆弱性検査と対策を実施する / 定期开展漏洞检查与应对)。
    - 🧠 **解析**：本次事故的根源在于DNS软件长期未升级、存在已知漏洞。通过定期开展脆弱性检查并及时打补丁，可以有效防止黑客利用已知漏洞夺取权限。
- **(2) 空白 b（引入EV证书后在浏览器可确认的信息）** 🏢

- ✅ **正解**：`ア` (会社名 / 组织/公司名称)。
- 🧠 **解析**：相较于域名验证（DV）证书，扩展验证（EV: Extended Validation）证书对申请者的法律及物理真实性进行严格审查，浏览器会展示经认证的**完整法律组织名称（公司名）**，使用户能确信访问的是真正的R公司官网。

- **(3) 下划线⑤（缓存DNS面向互联网开放会面临的攻击）** 💣
  - ✅ **正解**：`ア` (DDoS攻撃)。
  - 🧠 **解析**：开放的缓存DNS服务器极易被黑客用作反射放大攻击（DNS Amplification）的"踏脚石"，或者遭受随机子域名攻击（DNS Water Torture），导致服务器资源耗尽，构成 **DDoS 攻击**。
- **(4) 空白 c（通过随机化源端口应对的攻击手法）** 🧪
  - ✅ **正解**：`DNSキャッシュポイズニング` (DNS缓存毒化 / 14字)。
  - 🧠 **解析**：攻击者在缓存DNS向权威DNS发起查询时，抢先伪造响应包写入错误解析结果。通过启用源端口随机化（Source Port Randomization）和随机TXID，可以极大增加攻击者猜中校验信息的难度，有效防御 **DNS缓存毒化**。

🌟 三、 DNS安全与认证核心考点总结

🎯 核心考点	📖 案例场景	💡 核心知识点揭秘
权威 vs 缓存 DNS	权威存正本，缓存存副本。	权威DNS被改，源头污染；缓存DNS污染，局部受害，且受TTL过期时间制约。
EV 证书 (EV SSL/TLS)	用于增强Web官网的真实身份认证。	DV仅验域名所有权，EV严格验证企业实体身份，可展示**公司名称**，有效防御钓鱼假官网。
DNS Cache Poisoning	缓存DNS被灌入伪造解析。	防御手段：开启源端口随机化、随机TXID、部署 DNSSEC（DNS安全扩展）。
开放递归解析风险	缓存DNS不加限地对公网开放。	易被黑客滥用为反射放大踏脚石（DDoS）；防护：访问控制（仅限内网网段查询）。